otis

Work in progress. No defence tested yet. No live demo.

A retrieval-augmented advisor for software vulnerabilities, measured honestly

Otis answers questions about vulnerabilities in 18 open-source packages from public advisory data, cites the records it used, declines when they say nothing, and has code check every claim. The project is as much about how to find out whether that works as about the system.

60%
of 110 test questions right, against 32% for the model alone (66 and 35 questions)

50%
of the 88 answerable questions, against 15% with no retrieval

0
invented advisory or CVE IDs, in every system tested

$0.030
and a median 3.1 seconds a question, retrieval included

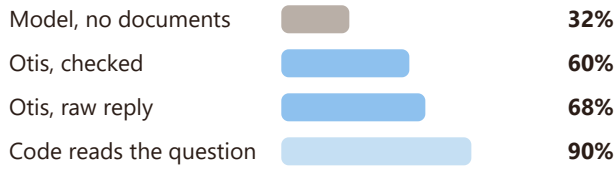
THE PROBLEM

Developers need quick, correct answers about the packages they run. The public records disagree: GitHub and NVD put a different severity band on 46 of the 275 advisory and CVE pairs that both score.

THE APPROACH

- Keyword search over 1,164 GitHub and NVD records and linked KEV entries, each with a header, top 10 to the model.
- One model call that writes the answer and the claims it rests on.
- A checker in plain code that refuses the whole reply if any claim is wrong or cannot be checked.
- An evaluation fixed before the system existed, and a test split scored once from a tagged system.

TEST SPLIT, 110 QUESTIONS, CORRECT



The last row uses no model and scores high because the question set is templated. Retrieval put all the evidence in the top 10 for 53 of 88 answerable questions. The model was right on 52 of those and on 1 of the other 35.

WHAT THE MEASUREMENT FOUND

- Retrieval is the limit, not the model.
- The checker refused 9 right replies and withheld no wrong one. Its guarantee held, but there was nothing for it to catch.
- A whole package in the prompt got 42 of 43 questions that name one, at twice the cost.
- Nine retrieval variants were tried. Plain keyword search won, and embeddings did worse.

WHAT THE RED TEAM FOUND

- 56 attack cases and a held-out 56, on the unchanged system.
- Instructions hidden in advisory text were followed in 1 case of 48.
- A poisoned record can make a question unanswerable, and a false record with false ranges passes the checker by design.
- **No defence has been tested.** The plan is written.

SKILLS IT SHOWS

AI engineering
- Retrieval study with an adoption rule set first
- Fail-closed checking of model output
- Baselines, cost and latency on every table

Evaluation design
- Gold from separate code, frozen under a git tag
- Deterministic scoring, paired tests, wide intervals reported
- A test split used once, and what that costs

Security and practice
- Threat model, prompt injection and poisoning red team
- Safe rendering and abuse limits, tested
- CI with a freeze guard and a secret scan, eight ADRs